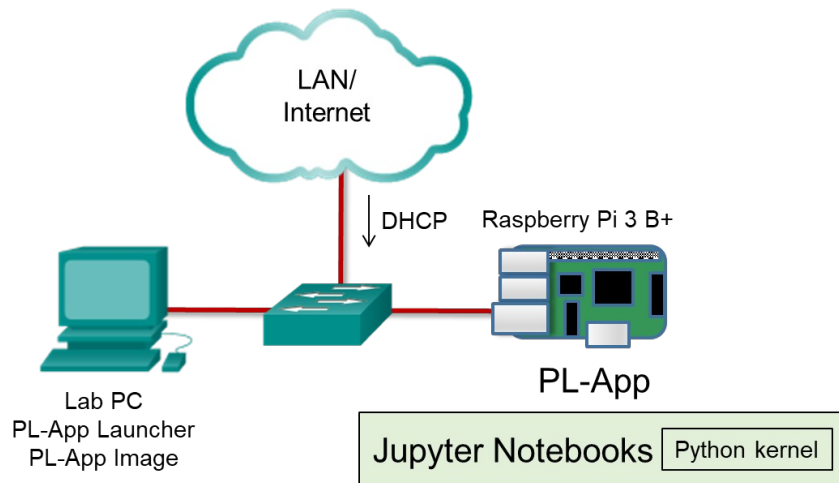


Lab - Port Scanning an IoT Device - Keep Standard Topology

Keep Standard Topology



Objectives

- Part 1: Perform a Nmap network discovery scan**
- Part 2: Compare a Nmap TCP default port scan and full scan**
- Part 3: Perform a Nmap UDP Scan**
- Part 4: Perform Nmap OS and Service Foot Printing**

Background / Scenario

Nmap, or "Network mapper," is a free and open source network port scanner. It can be used to test IoT devices and firewalls for open, closed, or filtered ports and additionally can provide an inventory of devices and services available on a network. Nmap uses the TCP header flag fields URG, ACK, PSH, RST, SYN, FIN, shown in the diagram, to accomplish its scans. It also uses other protocols such as UDP, ICMP and a built-in database of known OS and application signatures. Nmap is included with Kali, but can also be downloaded from <https://nmap.org/>. A comprehensive reference about how Nmap works and how it is used is available at the Nmap website.

Source Port				Destination Port				
Sequence Number								
Acknowledgement Number								
Data Offset	Reserved	URG	ACK	PSH	RST	SYN	FIN	Window
Checksum				Urgent Pointer				
Options				Padding				
Data								

Required Resources

- Raspberry Pi 3 Model B or later
- 8GB Micro SD card (minimum required)
- PC with IoTSec Kali VM
- Network connectivity between PC and Raspberry Pi

Part 1: Perform a Nmap Network Discovery Scan

Step 1: Use Kali to perform a host discovery scan.

The first step in network scanning is to discover the addresses of the hosts that are actually up on the network. This is because many network information gathering tasks, such as port scanning, are time-consuming. Nmap first scans the network to identify the addresses of hosts that should be scanned in greater depth. Doing in-depth scans of an entire network of 254 hosts, for example, is unnecessary if only a fraction of those hosts are actually on and able to respond.

By default, Nmap conducts a scan of the network to generate a list of hosts that are available for further scanning. It then conducts a port scan of those hosts.

- Start the IoTSec Kali VM and log in. Start the Raspberry Pi.
- Verify that Kali VM is assigned an IP address on eth0.

```
root@kali:~# ip a
```

- Open the man page for nmap in Kali VM and review the options that are available in Nmap.

```
root@kali:~# man nmap
```

Refer to the man page and complete the table below. There are many other resources available online to help you learn Nmap.

Option	Name	Notes
-sL	List Scan	simply list targets to scan
-sP	TCP SYN/ACK	UDP or SCTP discovery to given ports
-PN		Treat all hosts as online -- skip host discovery
-n		Never do DNS resolution/Always resolve [default: sometimes]

- Perform a scan on your network by specifying the network address and bit mask. Replace xxx.xxx.xxx by the first three octets of your network IP address. Depending on the number of hosts in your network this is going to take some time.

```
root@kali:~# nmap xxx.xxx.xxx.0/24
```

What is the IP address of the Raspberry Pi?

192.168.1.29

- e. Sometimes a device would not reply to Nmap's initial network discovery scan because of a **firewall**, **IDS/IPS system** etc. Instead of relying on the initial scan to discover hosts that are alive for further scanning, we can use Nmap to scan the network by assuming all hosts are alive. This scan will therefore take even longer than the previous one. Thus, we use the **-T5** parameter to speed up the scan process. However this scan can still take up to 3 minutes! Time to grab a coffee or for some other kind of break...

```
root@kali:~# nmap -PN -T5 xxx.xxx.xxx.0/24
```

You will probably see some warnings that some port scan are given up due to the stricter timing requirements. Note that the quicker scans can also be detected more easily by intrusion detection systems (IDS).

What is the **IP address and MAC address of your Raspberry Pi**?

192.168.1.29

Part 2: Compare a Nmap TCP Default Scan and Full Scan

Step 1: **Using Wireshark to display Nmap scans**

- a. In a Kali VM terminal, start Wireshark. Wireshark is used to monitor the traffic while scanning the network using Nmap. Click **OK** for the warning message regarding running Wireshark as a root user.

```
root@kali:~# wireshark &
```

- b. Double click on the eth0 interface to start the capture or select the eth0 interface and click **Capture** or **Aufzeichnen** and **Start**.
- c. There can be a lot of traffic on the network. A display filter is applied to limit the number of captured packets displayed to just those that you are interested in. The interesting traffic is between the IP address of the Kali VM and the IP address of the Raspberry Pi.

Apply the following display filter in Wireshark using IP address of Kali VM as the source address and IP address of your Raspberry Pi as the destination address:

```
ip.src == kkk.kkk.kkk.kkk && ip.dst == rrr.rrr.rrr.rrr
```

where **kkk.kkk.kkk.kkk** is the IP address of the Kali VM and **rrr.rrr.rrr.rrr** is the IP address of the Raspberry Pi.

Step 2: Nmap TCP default scan

- a. In the terminal, enter the following command to start the Nmap scanning.

```
root@kali:~# nmap rrr.rrr.rrr.rrr
```

After Nmap reports the result of the scan, **stop** the Wireshark capture. Click the **arrow next to the display filter field to filter the results of the scan**.

Review the Wireshark output. Which TCP flag is Nmap using to discover the open ports?

SYN

Notice the ports that are being tested. The default Nmap scan does not test all ports. How many ports does a default Nmap scan test? (Do a web search if necessary.)

1000

Look at the results of the nmap scan in the terminal. What ports are identified?

2 Ports : -->

Not shown: 998 closed ports

PORT STATE SERVICE

22/tcp open ssh

80/tcp open http

Step 3: Nmap TCP full TCP port scan

- Nmap by default only scan a limited number of TCP ports. We would like to scan all 65535 TCP ports.
- Start a new Wireshark capture by clicking on the shark fin icon below **File** or **Datei**. Click **Continue without Saving** or **Fortsetzen ohne zu Speichern** when prompted to save the capture.
- Enter the nmap command to scan all the TCP ports in Kali VM.


```
root@kali:~# nmap -p 1-65535 rrr.rrr.rrr.rrr
```
- Watch the Wireshark capture screen. Notice you are sending TCP packets just as before, but the number of ports being scanned has increased.
- Stop the Wireshark capture by clicking the red stop icon just right to the shark fin icon when finished and clear the filter by clicking the **x** icon at the right end of the filter line.

Part 3: Perform a Nmap UDP scan

192.168.1.215 kali

UDP Header Format

Source Port	Destination Port
Length	Checksum

Step 1: UDP scan with a new Wireshark filter.

- Start a new Wireshark capture by clicking on the shark fin icon below **File** or **Datei**. Click **Continue without Saving** or **Fortsetzen ohne zu Speichern** when prompted to save the capture.
- Apply the following filter in Wireshark:

`ip.src == kkk.kkk.kkk.kkk && udp`

This will allow us to see the UDP traffic generated by nmap to the Raspberry Pi. Notice in the UDP header above there are no flags. We can only send UDP packets and receive a possible "port unreachable or destination unreachable" message meaning the port is closed.

- In the Kali VM terminal, enter the command **nmap** with **-sU** option scanning the IP address of your Raspberry Pi.

```
root@kali:~# nmap -sU -F rrr.rrr.rrr.rrr
```

- It will take a few minutes, but look at the Wireshark capture. As you scroll down the packets, you will see some "Destination unreachable" on different ports indicating the port is closed.

How many UDP ports are there? How many UDP ports does Nmap scan, by default? (Use web search as necessary.)

65 535

1000

What are the UDP ports that are open from the scan? What protocols use these UDP ports?

ZB: 33711, 518, 120, 20031, 626

What is the meaning of the **-F** option? Try the same scan without the **-F**. What is the difference?

-F: Fast mode - Scan fewer ports than the default scan

- e. Stop the Wireshark capture by clicking the red stop icon just right to the shark fin icon when finished and clear the filter by clicking the x icon at the right end of the filter line.

Part 4: Perform Nmap OS and Service Foot Printing

Step 1: Use Nmap to find a device operating system.

Nmap can guess the operating system of a device based on its response to a series of TCP and UDP packets.

- a. Start a new Wireshark capture by clicking on the shark fin icon below **File** or **Datei**. Click **Continue without Saving** or **Fortsetzen ohne zu Speichern** when prompted to save the capture.
- b. Apply the following filter in Wireshark using IP address of Kali VM as the source address and IP address of your Raspberry Pi as the destination address.

```
ip.src == kkk.kkk.kkk.kkk && ip.dst == rrr.rrr.rrr.rrr
```

- c. In the Kali VM terminal, enter the command **nmap** using the -O option scanning the IP address of your Raspberry Pi.

```
root@kali:~# nmap -O rrr.rrr.rrr.rrr
```

What operating system did Nmap guess?

No exact OS matches for host (If you know what OS is running on it, see <https://nmap.org/submit/>).

TCP/IP fingerprint:

```
OS:SCAN(V=7.60%E=4%D=6/18%OT=22%CT=1%CU=32827%PV=Y%DS=1%DC=D%G=Y%M=B827EB%I
OS:M=62AD8EEE%P=x86_64-pc-linux-gnu)SEQ(SP=FE%GCD=1%ISR=109%TI=Z%CI=Z%II=I%
```

Look at the packets in Wireshark. What protocols were used to determine the OS?

TCP ;ICMP

- d. We can sometimes identify a device by looking at the time to live (TTL) field of a local ping response, which varies by device OS. See the table below:

Operating System	TTL Response time
Cisco	255
Windows	128
Linux	64

In the Kali VM terminal, enter the command to ping your Raspberry Pi with 4 ICMP packets.

```
root@kali:~# ping -c4 rrr.rrr.rrr.rrr
```

What is the response time? Is it consistent with the Nmap identification?

64

yes

- e. Stop the Wireshark capture when finished.

Step 2: Use Nmap to find services versions

Nmap has a built-in database of about 2,200 well-known services that is used to help identify application service versions.

- Start a new Wireshark capture by clicking on the shark fin icon below **File** or **Datei**. Click **Continue** **without Saving** or **Fortsetzen ohne zu Speichern** when prompted to save the capture. Apply the same display filter as the previous step.
- In the Kali VM, enter the **nmap** command with the **-A** option scanning the IP address of your Raspberry Pi:

```
root@kali:~# nmap -A rrr.rrr.rrr.rrr
```

What are the identified applications running on the ports? Complete the table.

Port Number	Application service identified
22/tcp	ssh
80/tcp	http

What is different in the port identification from the Nmap TCP scan in Part 2 of the lab and this application service scan? What implications does this have for IoT security?

There are additional functions as version and host key

What additional functions does this scan also perform?

- Stop the Wireshark capture when finished.
- Power down the VM and the